

Denial of service attack



Contents

- **Introduction**
- **Classical DoS attacks**
- **Flooding attacks**
- **Distributed Denial-of-Service (DDoS)**
- **How DDoS attacks are waged?**
- **Reflector and amplifier attacks**
- **Other DoS attacks**
- **Detecting DoS attacks**
- **Approaches to defense against DoS**
- **Responding to a DoS attack**
- **Conclusion**



Definition

- **Denial-of-service (DoS) attack** aims at **disrupting the authorized use** of networks, systems, or applications
 - by sending messages which exhaust service provider's resources (network bandwidth, system resources, application resources)
- **Distributed denial-of-service (DDoS) attacks** employ multiple (dozens to millions) compromised computers to perform a coordinated and widely distributed DoS attack
- **Victims** of (D)DoS attacks
 - service-providers (in terms of time, money, resources, good will)
 - legitimate service-seekers (deprived of availability of service itself)
 - Zombie systems(Penultimate and previous layers of compromised systems in DDoS)



Analyzing the goal of DoS attacks

- A (D)DoS attack is *different in goal* : **iWar**, in short
 - Just deny availability
 - Can work on any port left open
 - No intention for stealing/theft of information
 - Although, in the process of denying service to/from victim, *Zombie* systems may be hijacked



Who? What for?

● The ulterior motive

- Earlier attacks were proofs of concepts or simple pranks
- Pseudo-supremacy feeling (of defaulters) upon denying services in large scale to normal people
 - DoS attacks on Internet chat channel moderators
- Eye-for-eye attitude
- Political disagreements
- Competitive edge
- Hired

● Major lack of data on perpetrators and motives

● Levels of attackers

- Highly proficient attackers who are rarely identified or caught
- Script-kiddies

Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



Why should we care?

- As per 2006 CSI/FBI Computer Crime and Security Survey
 - 25% of respondents faced some form of DoS attacks in previous 12 months. This value varied from 25% to 40% over the course of time
 - DoS attacks are the **5th most costly** form of attacks
- A DoS attack is not just missing out on the latest sports scores or Tweets or weather reports
- Internet is now a critical resource whose disruption has financial implications, or even dire consequences on human safety
 - **Cybercrime** and **cyberwarfare** might use of DoS or DDoS as a potential weapon to disrupt or degrade critical infrastructure
 - DDoS attacks are a major threat to the stability of the Internet

Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



Fast facts

- In Feb 2000, series of massive DoS attacks incapacitated several high-visibility Internet e-commerce sites, including **Yahoo, Ebay and E*trade**
- In Jan 2001, **Microsoft's name sever** infrastructure was disabled
 - 98% legitimate users could not get to any Microsoft's servers
- In Sept 2001, an attack by a UK-based teenager on the **port of Houston's Web server**, made weather and scheduling information unavailable
 - No ships could dock at the *world's 8th busiest maritime* facility due to lack of weather and scheduling information
 - Entire network performance was affected
- In Oct 2002, all **Domain Name System servers** were attacked
 - Attack lasted only an hour
 - 9 of the 13 servers were seriously affected
- In Aug 2009, the attack on **Twitter and Facebook**



Approaches to DoS attacks

- Internet designed for minimal-processing and best-effort forwarding any packet
 - Make shrewd use of flaws in the Internet design and systems
 - Unregulated forwarding of Internet packets : Vulnerability ,Flooding
- **Vulnerability attack**
 - *Vulnerability* : a bug in implementation or a bug in a default configuration of a service
 - *Malicious messages* (exploits) : unexpected input that utilize the vulnerability are sent
 - Consequences :
 - The system slows down or crashes or freezes or reboots
 - Target application goes into infinite loop
 - Consumes a vast amount of memory
 - Ex : Ping of death, teardrop attacks, etc.

Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



Approaches to DoS attacks cont'd

● Flooding attack

- Work by sending a vast number of messages whose processing consumes some key resource at the target
- The strength lies in the volume, rather than the content
- Implications :
 - Make the traffic look **legitimate**
 - Flow of traffic is **large** enough to consume victim's resources
 - Send with **high packet rate**
 - These attacks are more commonly DDoS
- Ex : SYN spoofing attack, Source address spoofing, cyberslam, etc.

Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



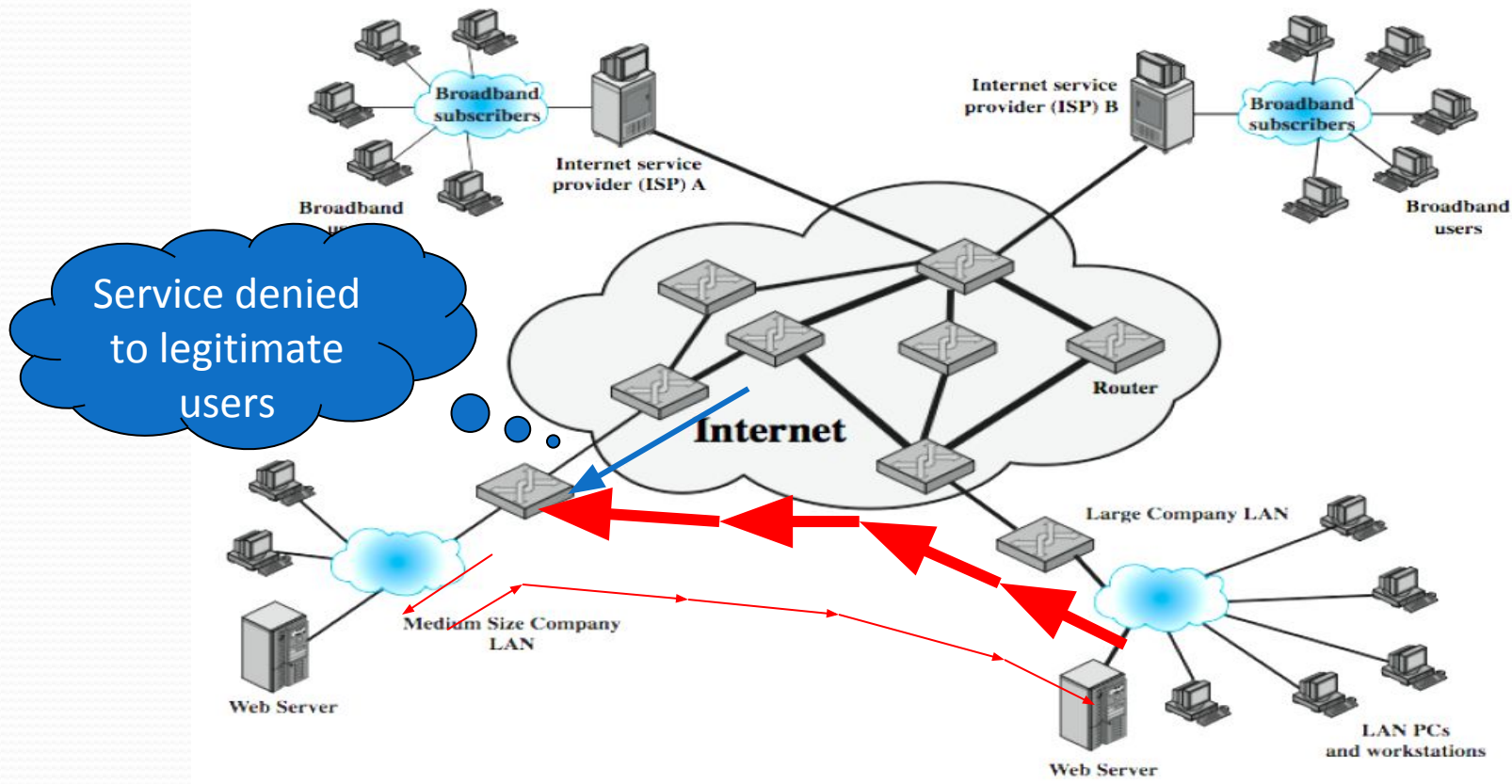
Contents

- Introduction
- Classical DoS attacks
- Flooding attacks
- Distributed Denial-of-Service (DDoS)
- How DDoS attacks are waged?
- Reflector and amplifier attacks
- Other DoS attacks
- Detecting DoS attacks
- Approaches to defense against DoS
- Responding to a DoS attack
- Conclusion



Classical DoS attacks

- Simplest classical DoS attack: Flooding attack on an organization
 - Ping flood attack



Ping flood attack

- Use of ping command options `-n -l`

Ping of Death

```
Microsoft Windows [Version 6.0.6000]
Copyright (c) 2006 Microsoft Corporation. All rights reserved.

C:\Users\Z>ping 127.0.0.1 -n 5 -l 65500

Pinging 127.0.0.1 with 65500 bytes of data:

Reply from 127.0.0.1: bytes=65500 time<1ms TTL=128
Reply from 127.0.0.1: bytes=65500 time<1ms TTL=128
Reply from 127.0.0.1: bytes=65500 time<1ms TTL=128
Reply from 127.0.0.1: bytes=65500 time<1ms TTL=128
Reply from 127.0.0.1: bytes=65500 time<1ms TTL=128

Ping statistics for 127.0.0.1:
    Packets: Sent = 5, Received = 5, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms

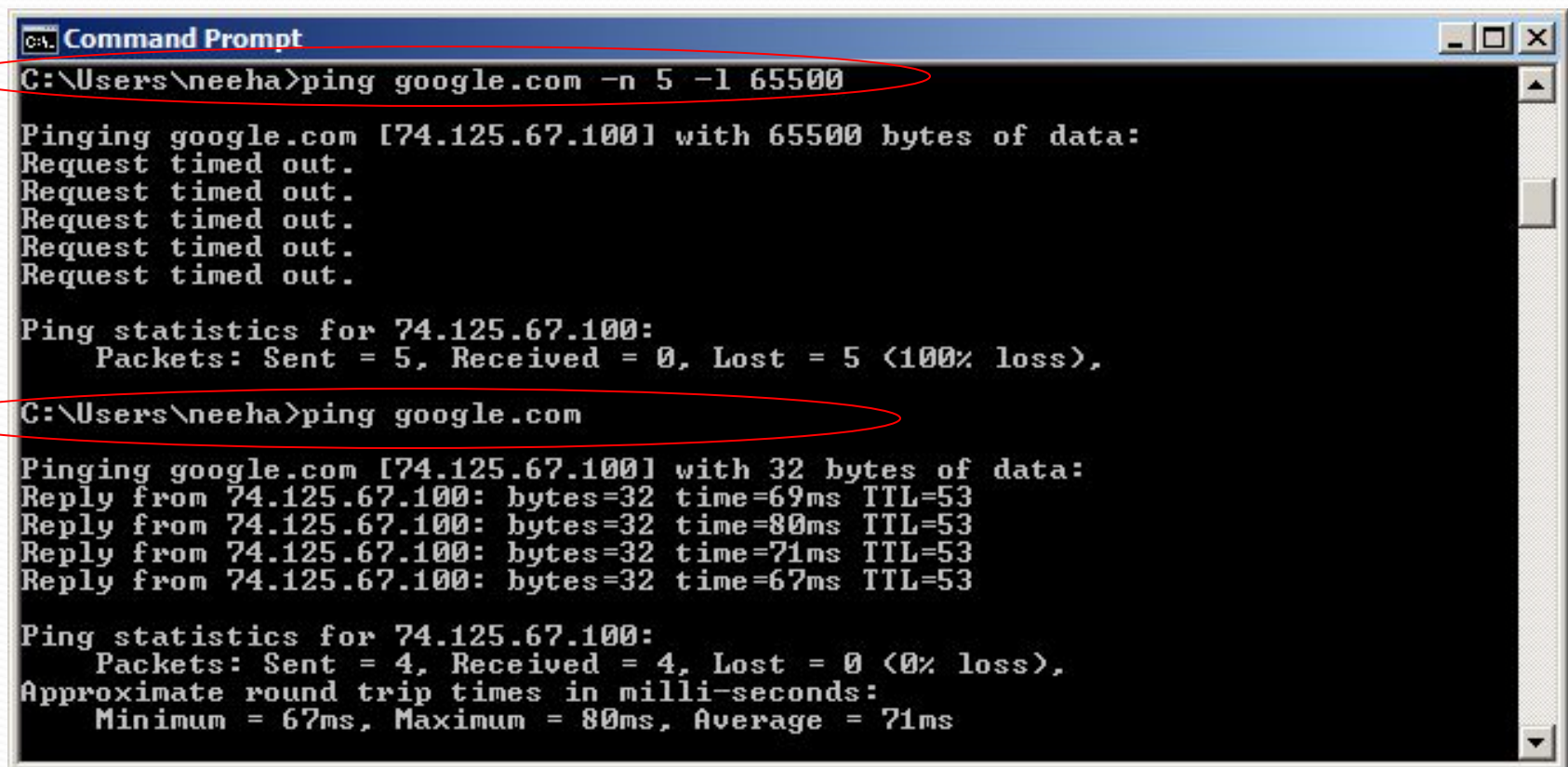
C:\Users\Z>_
```

Source: learn-networking.com



Ping flood attack cont'd

- Generally useless on larger networks or websites



```
Command Prompt
C:\Users\neeha>ping google.com -n 5 -l 65500

Pinging google.com [74.125.67.100] with 65500 bytes of data:
Request timed out.
Request timed out.
Request timed out.
Request timed out.
Request timed out.

Ping statistics for 74.125.67.100:
    Packets: Sent = 5, Received = 0, Lost = 5 (100% loss),

C:\Users\neeha>ping google.com

Pinging google.com [74.125.67.100] with 32 bytes of data:
Reply from 74.125.67.100: bytes=32 time=69ms TTL=53
Reply from 74.125.67.100: bytes=32 time=80ms TTL=53
Reply from 74.125.67.100: bytes=32 time=71ms TTL=53
Reply from 74.125.67.100: bytes=32 time=67ms TTL=53

Ping statistics for 74.125.67.100:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 67ms, Maximum = 80ms, Average = 71ms
```



Disadvantage to attacker

- Attacker's source is easily identified
- Chances of attack flow being reflected back to attacker

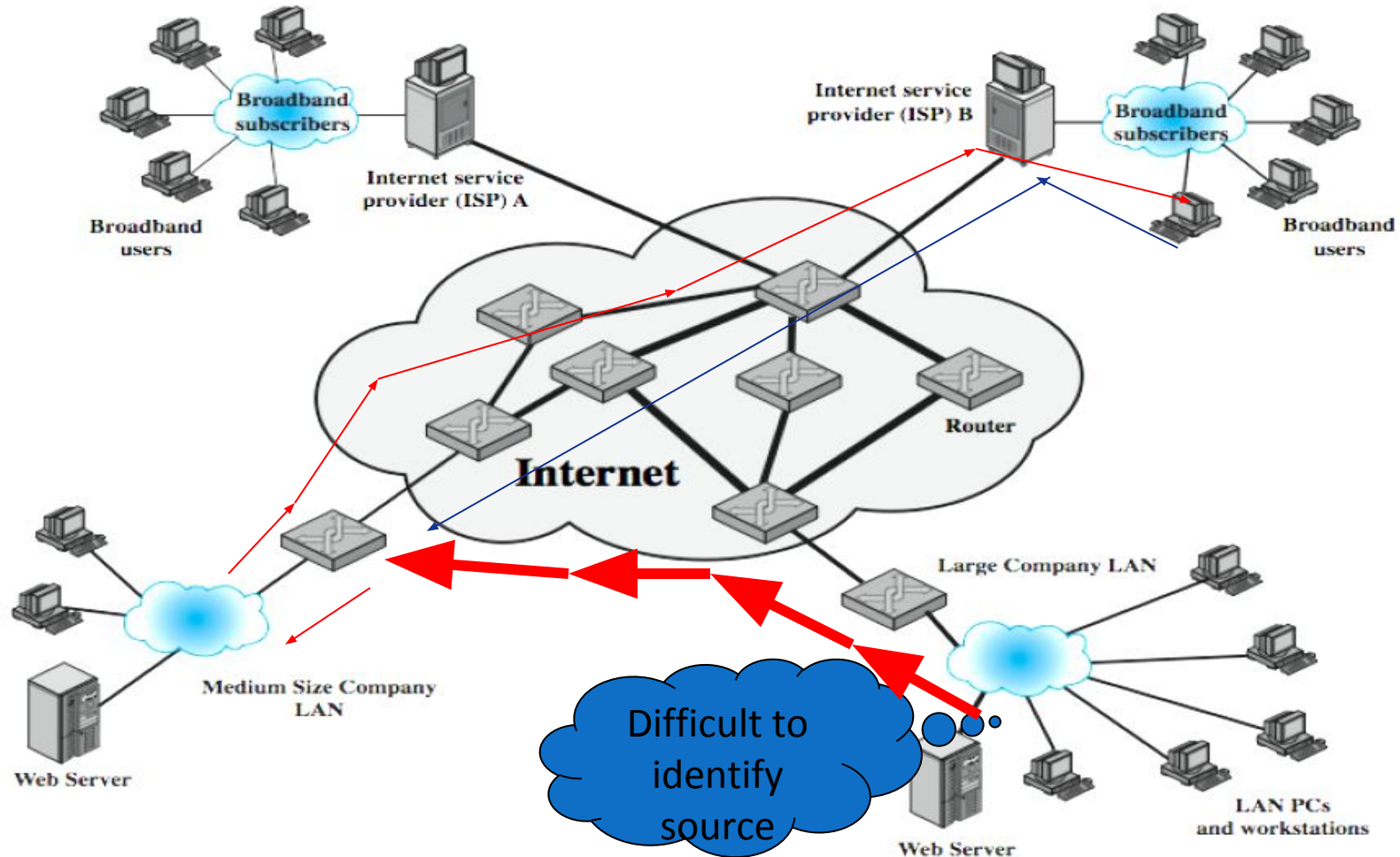


Source address spoofing

- **Falsification** : Use of forged source IP address
- Privileged access to network handling code via **raw socket interface**
 - Allows direct sending and receiving of information by applications
 - Not needed for normal network operation
- In absence of privilege, install a **custom device driver** on the source system
 - Error prone
 - Dependent on operating system version



Spoofing via raw socket interface



Spoofing via raw socket interface cont'd....

- Unfortunately removal of raw sockets API is not an apt solution to prevent DoS attacks
 - Microsoft's removal of raw sockets API in the release of Windows XP Service Pack 2 in August 2004 was expected to break applications like the public domain nmap port scanner
 - In just a few days, a workaround was produced restoring the ability of nmap to craft custom packets
 - <http://seclists.org/nmap-hackers/2004/0008.html>

Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)

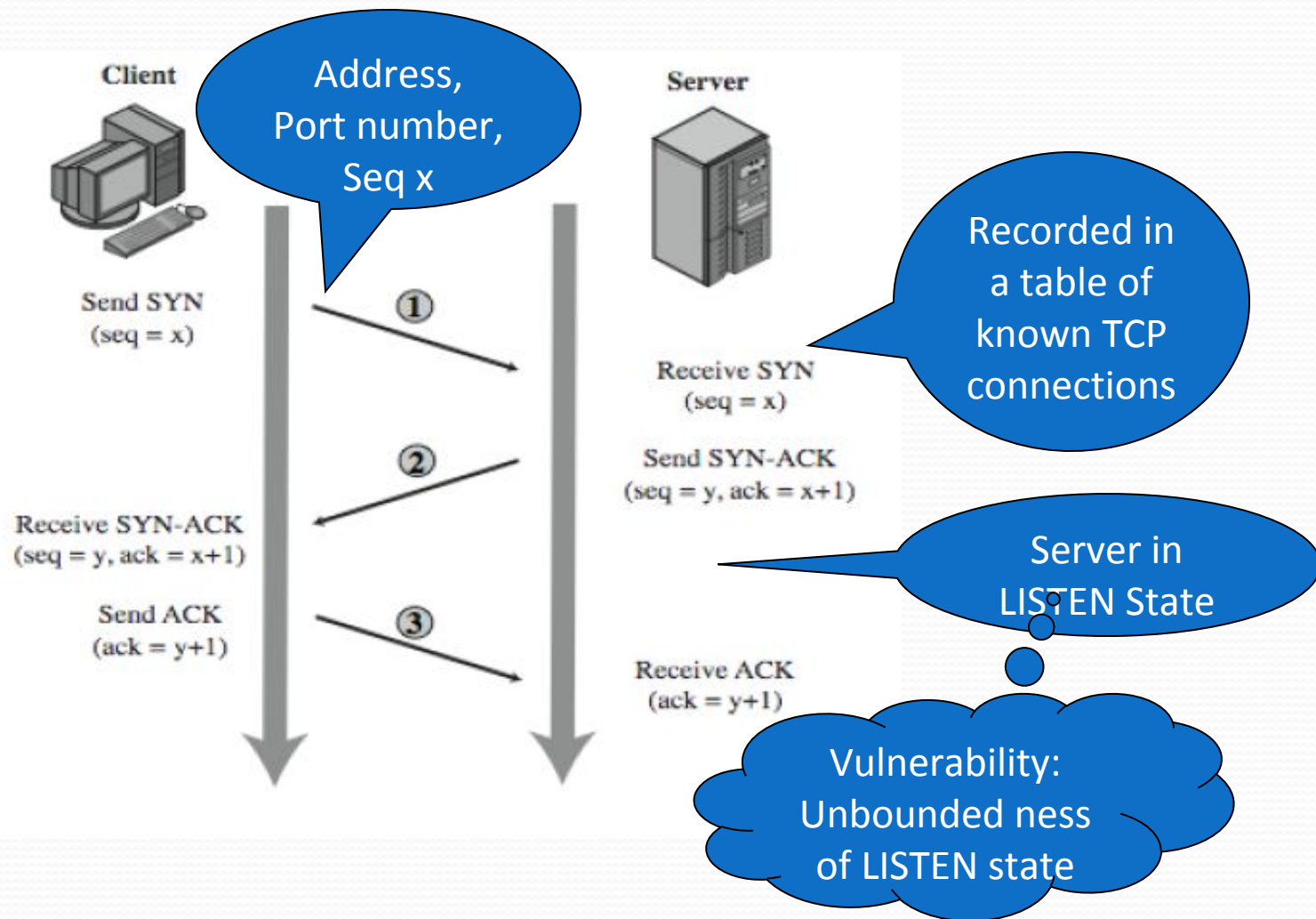


SYN spoofing

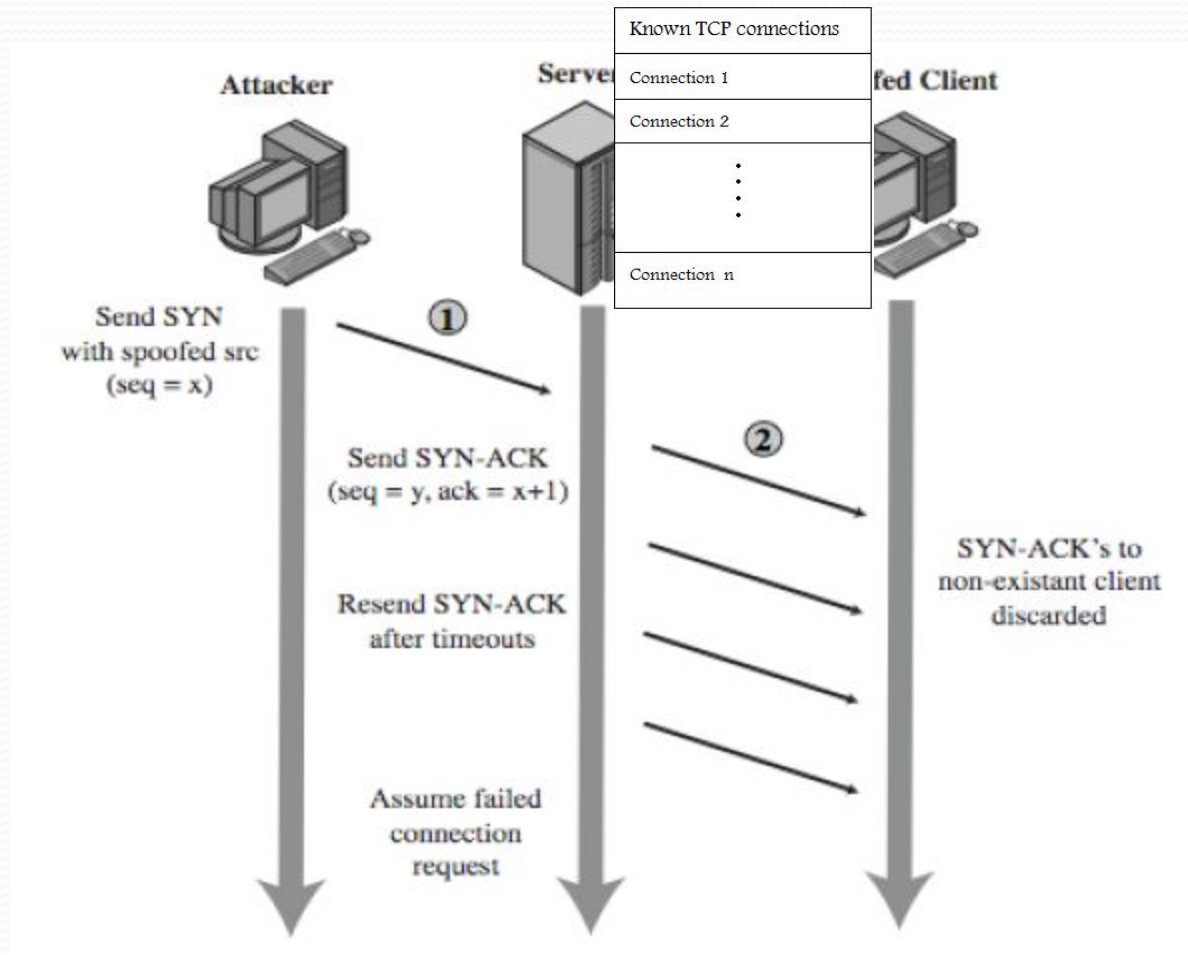
- Takes advantage of the ***three-way handshake*** that occurs any time two systems across the network initiate a TCP connection request
- Unlike usual brute-force attack, not done by exhausting network resources but done by ***overflowing the system resources*** (tables used to manage TCP connections)
- **Require fewer packets** to deplete
- Consequence: **Failure of future connection requests** ,thereby denying access to the server for legitimate users
- Example: land.c sends TCP SYN packet using target's address as source as well as destination



TCP 3-way connection handshake



SYN spoofing cont'd



Factors considered by attacker for SYN spoofing

- The number of sent forged packets are just **large enough to exhaust the table** but small as compared to a typical flooding attack
- Keep sufficient volume of forged requests **flowing**
 - Keep the table constantly full with no timed-out requests
- Make sure to use addresses that will **not respond to the SYN-ACK with a RST**
 - Overloading the spoofed client
 - Using a wide range of random addresses
 - A collection of compromised hosts under the attacker's control (i.e., a "botnet") could be used



Detecting SYN spoof attack

- After the target system has tried to send a SYN/ACK packet to the client and while it is waiting to receive an ACK packet, the existing connection is said to be half open or host in SYN_RECEIVED state
- If your system is in this state, it may be experiencing SYN-spoof attack
- To determine whether connections on your system are half open, type **netstat -a** command
- This command gives a set of active connections .Check for those in the state **SYN_RECEIVED** which is an indication of the threat of SYN spoof attack

Source: Fadia (2007)



Analysing traffic

- Spoofing makes it difficult to trace back to attackers
- Analysing flow of traffic required but not easy!
 - Requires cooperation of the network engineers managing routers
 - Query flow information: a manual process
- How about filtering at source itself ?
- **Backscatter traffic** : used to infer type and scale of DoS attacks
 - Utilise ICMP echo response packets generated in response to a spoofed ping flood



Contents

- Introduction
- Classical DoS attacks
- Flooding attacks
- Distributed Denial-of-Service (DDoS)
- How DDoS attacks are waged?
- Reflector and amplifier attacks
- Other DoS attacks
- Detecting DoS attacks
- Approaches to defense against DoS
- Responding to a DoS attack
- Conclusion



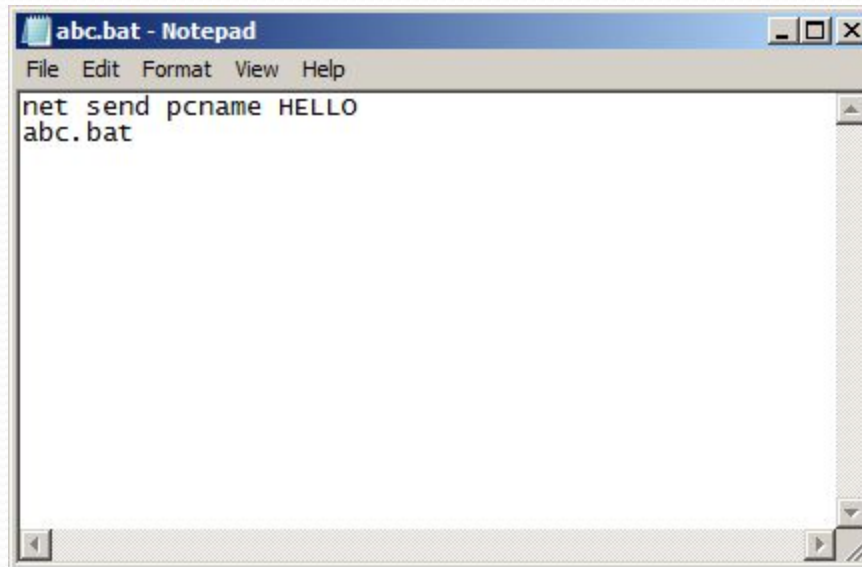
Flooding attacks

- Goal : **Bombarding large number** of malicious packets at the victim, such that processing of these packets consumes resources
- **Any type of network packet** can be used
 - Attack traffic made similar to legitimate traffic
- Valid traffic **has a low probability of surviving the discard** caused by flood and hence accessing the server
- Some ways of flooding :
 - To overload network capacity on some link to a server
 - To overload server's ability to handle and respond to this traffic
- The larger the packet, the more effective the attack



Flooding attack within local network

- Simply sending infinite messages from one computer to another on the local network , thereby wasting the resources of the recipient computer to receive and tackle the messages
- The following code (abc.bat) sends infinite messages to victim



```
abc.bat - Notepad
File Edit Format View Help
net send pcname HELLO
abc.bat
```

Types of flooding attacks

- Classified based on type of network protocol used to attack
- **ICMP flood**
 - Uses ICMP packets , ex: ping flood using echo request
 - Typically allowed through, some required
- **UDP flood**
 - Exploits the target system's diagnostic echo services to create an infinite loop between two or more UDP services
- **TCP SYN flood**
 - Use TCP SYN (connection request packets)
 - But for volume packet



Indirect attacks

- Single-sourced attacker would be traced
- Scaling would be difficult
- Instead use **multiple** and **distributed** sources
 - None of them generates traffic to bring down its own local network
 - The Internet delivers all attack traffic to the victim
- Thus, victims service is denied while the attackers are still fully operational
- Indirect attack types
 - Distributed DoS
 - Reflected and amplifier attacks



Contents

- Introduction
- Classical DoS attacks
- Flooding attacks
- Distributed Denial-of-Service (DDoS)
- How DDoS attacks are waged?
- Reflector and amplifier attacks
- Other DoS attacks
- Detecting DoS attacks
- Approaches to defense against DoS
- Responding to a DoS attack
- Conclusion



Distributed Denial-of-service

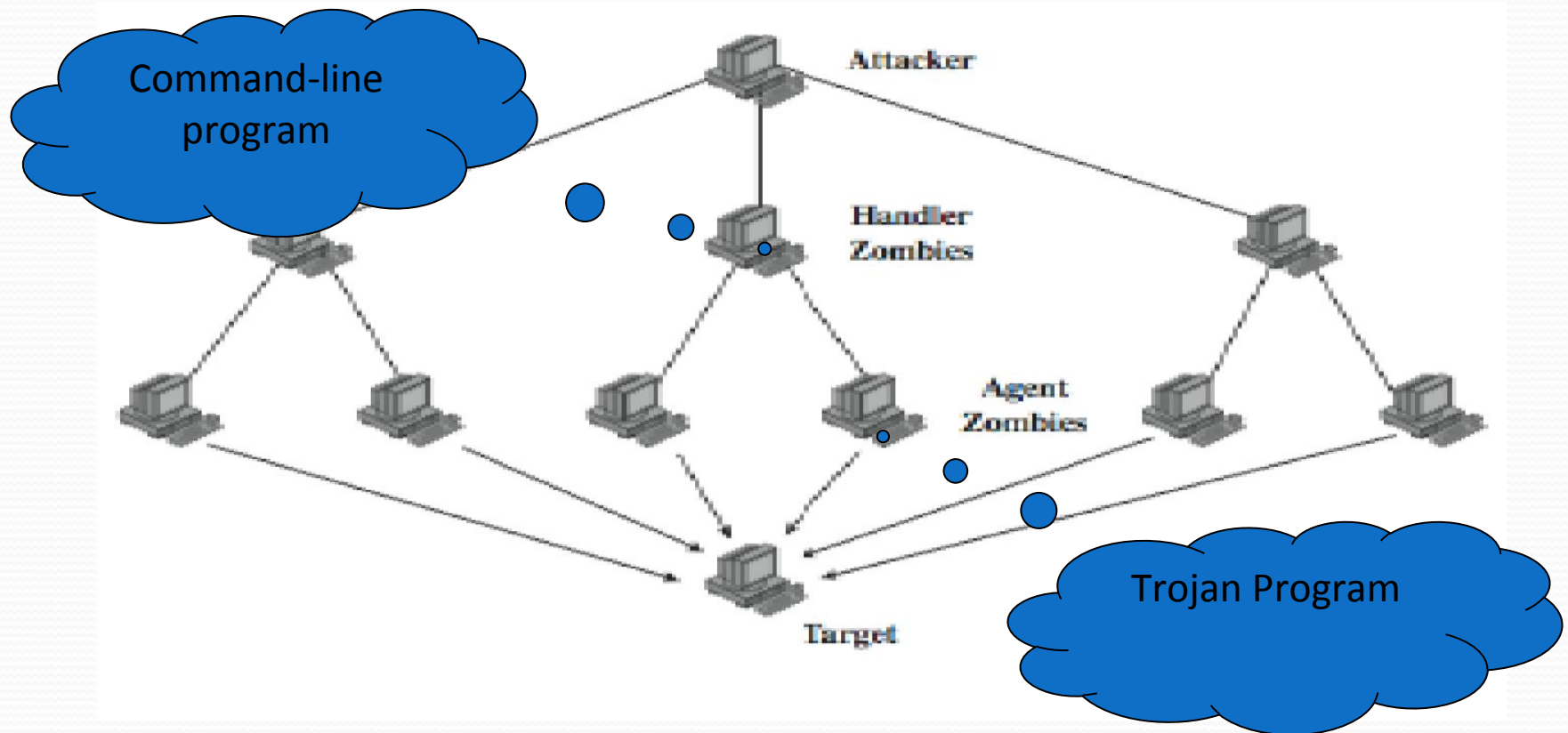
- Attacker uses multiple compromised user work stations/PCs for DoS by:
 - Utilising vulnerabilities to gain access to these systems
 - Installing malicious backdoor programs , thereby making ***zombies***
 - Creating ***botnets***: large collection of zombies under the control of attacker
- Generally, a **control hierarchy** is used to create botnets
 - ***Handlers***: The initial layer of zombies that are directly controlled by the attacker
 - ***Agent systems***: Subordinate zombies that are controlled by handlers
 - Attacker sends a single command to handler, which then automatically forwards it to all agents under its control
- Example: Tribe Flood Network (TFN), TFN2K



DDoS control hierarchy

- Example: Tribe Flood Network (TFN)

- Relied on **large number** of compromised systems and **layered command**



Contents

- Introduction
- Classical DoS attacks
- Flooding attacks
- Distributed Denial-of-Service (DDoS)
- How DDoS attacks are waged?
- Reflector and amplifier attacks
- Other DoS attacks
- (D)DoS attack trends
- Detecting DoS attacks
- Approaches to defense against DoS
- Responding to a DoS attack
- Conclusion



How DDoS attacks are waged ?

- Recruitment of the agent network
- Controlling the DDoS agent network
- Use of appropriate toolkits
- Use of IP Spoofing

Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



Recruitment of the agent network

- Scanning
- Breaking into vulnerable machines
 - Malware propagation

Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



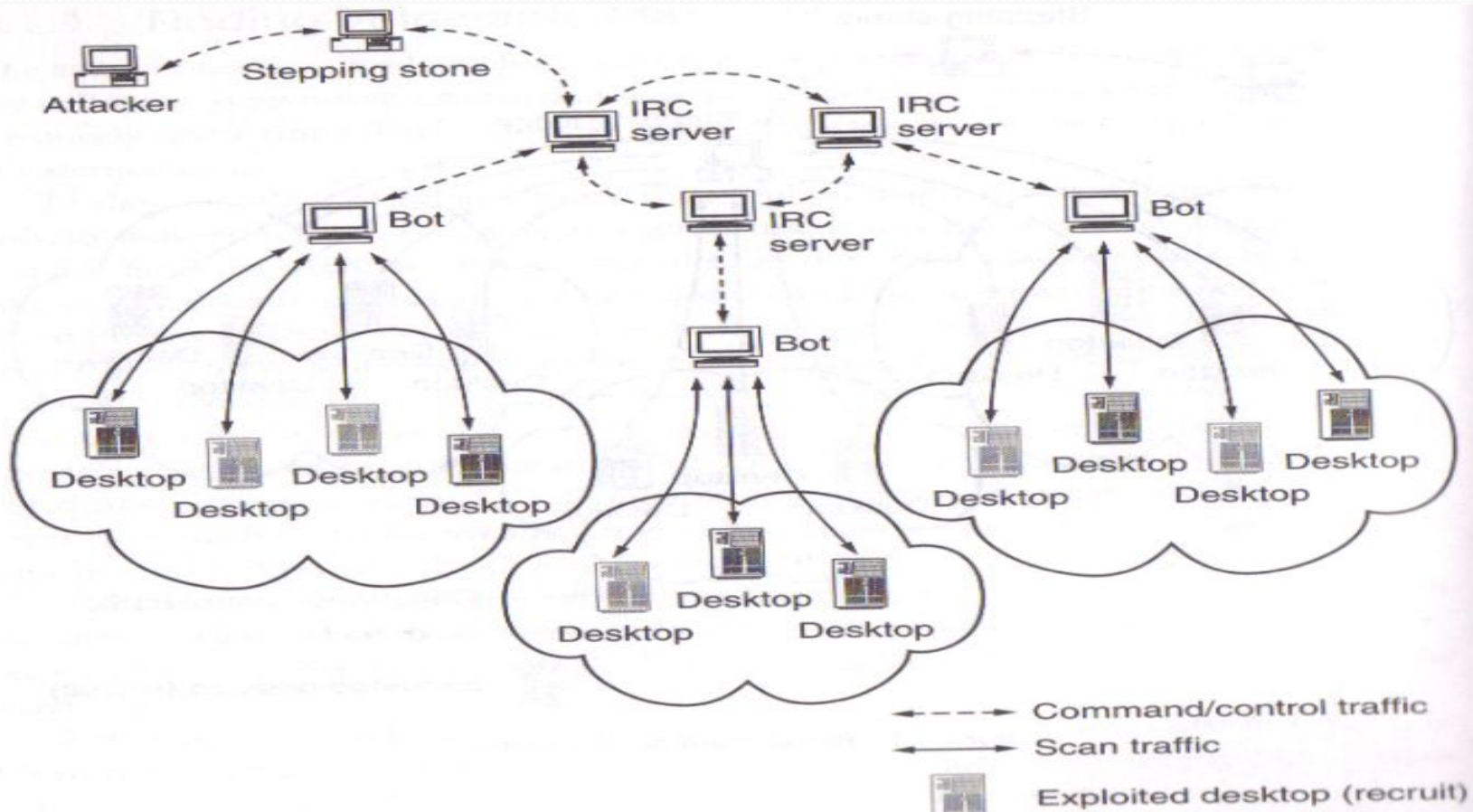
Scanning

- Find sufficiently **large number** of vulnerable machines
 - Manual or semi-automatic or completely automatic process
 - Trinoo: discovery and compromise is manual but only installation is automated
 - <http://staff.washington.edu/dittrich/misc/trinoo.analysis.txt>
 - Slammer-, MyDoom- : automated process
- Recruit machines that have sufficiently **good connectivity**
- Netblock scans are initiated sometimes
 - Based on random or explicit rationale
- Examples of scanning tools : IRC bot , worms

Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



Scanning using IRC bot



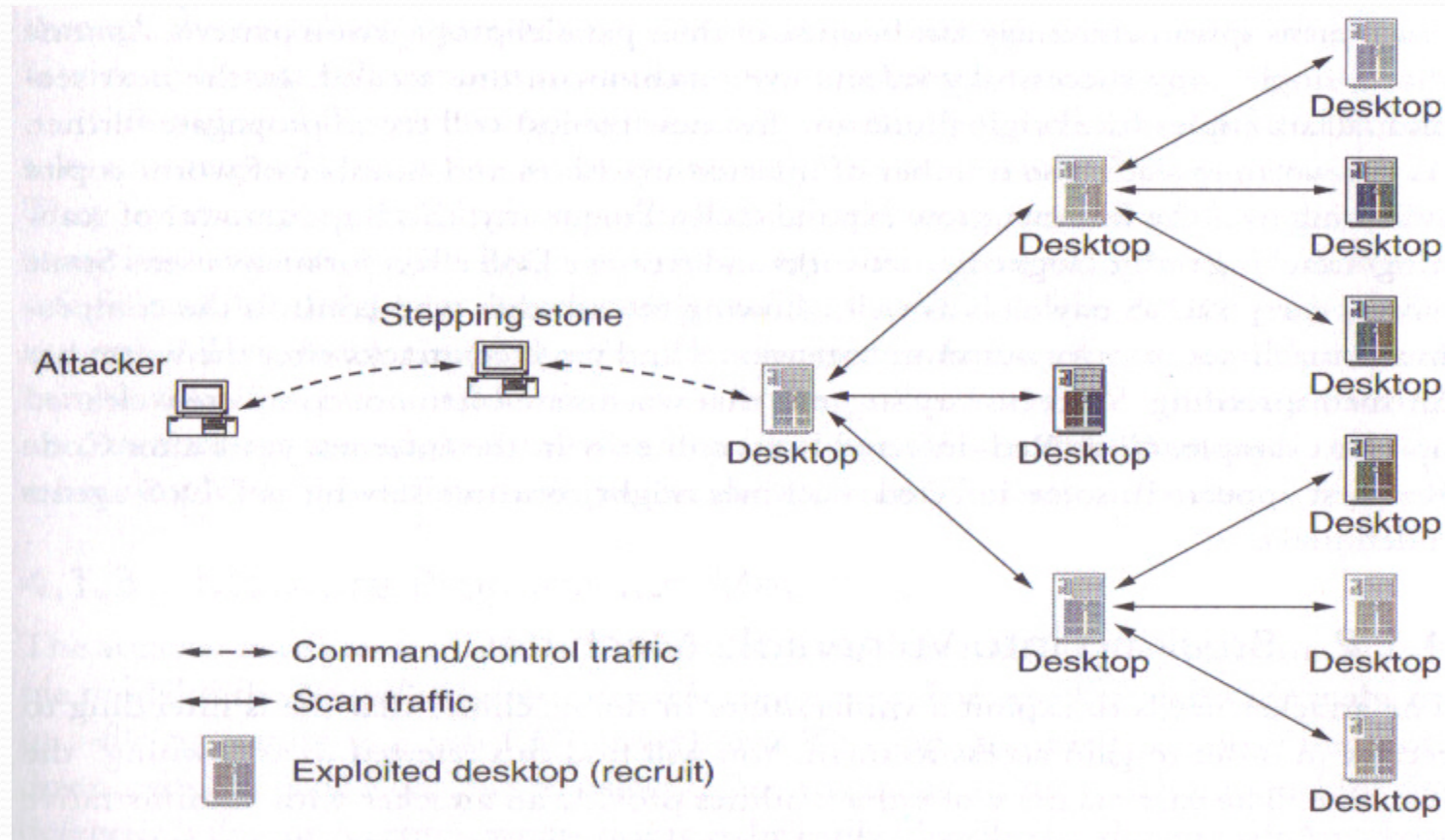
Scanning using worms

- Popular method of recruiting DDoS agents
- Scan/infect cycle repeats on both the infected and infecting machines
- Worms spread extremely fast because of their **parallel propagation pattern**
- Worms choice of address for scanning
 - Random
 - Random within a specific range of addresses
 - Using hitlist
 - Using information found on infected machines
- Worms are **often not completely cleaned up**
 - Some infected machines might continue serving as DDoS agents indefinitely!
 - Code Red – infected hosts still exist in the Internet

Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



Scanning using worms cont'd



Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



Breaking into vulnerable machines

- Most vulnerabilities provide an attacker with **administrative access to system**
- Attacker updates his DDoS toolkit with new exploits
 - Propagation Vectors

Vulnerability Exploitation cycle

New vuln. discovered



Exploited at larger scale



Automated tools appear



Patches for vuln. appear



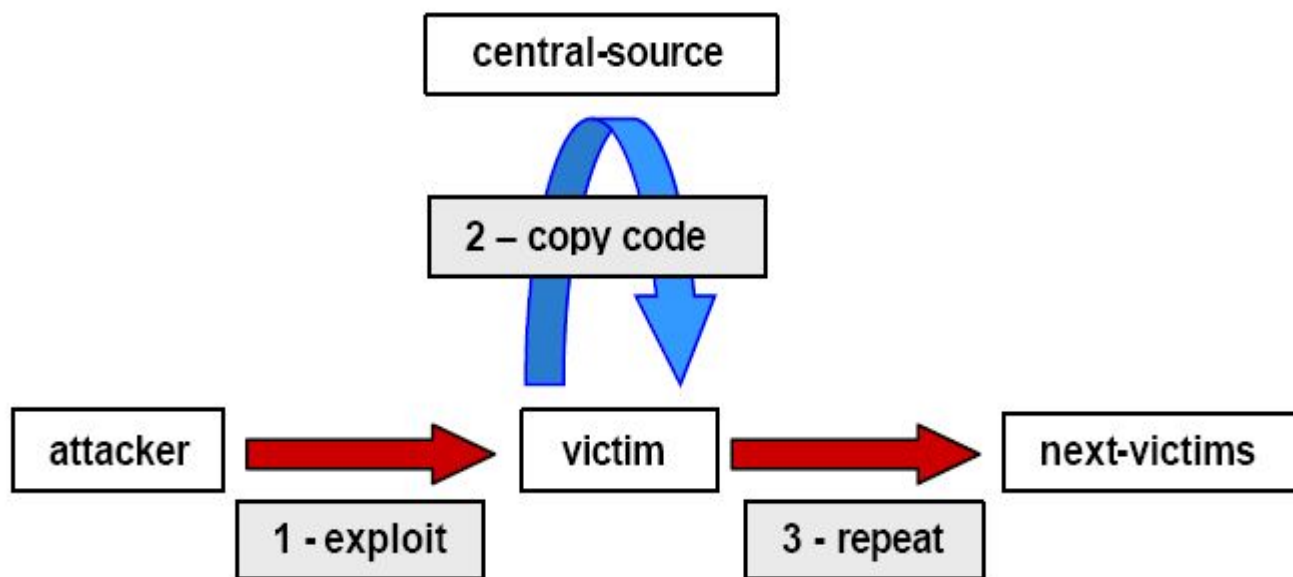
Exploits for a vuln. decline

Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



Malware propagation

- Propagation with central repository or cache approach
 - Advantage for defender: central repositories can be easily identified and removed
 - Ex: trinoo , Shaft etc

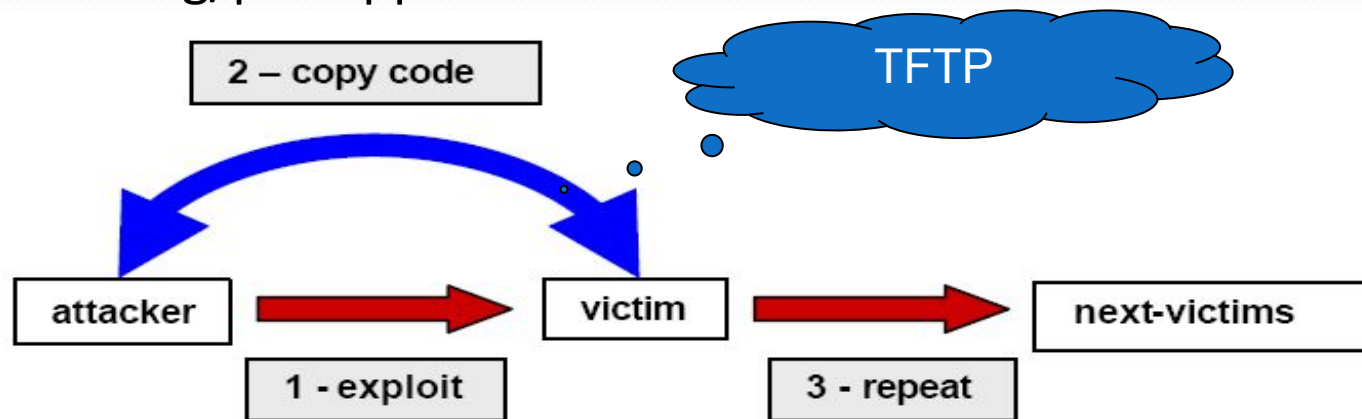


Source: www.cert.org/archive/pdf/DoS_trends.pdf

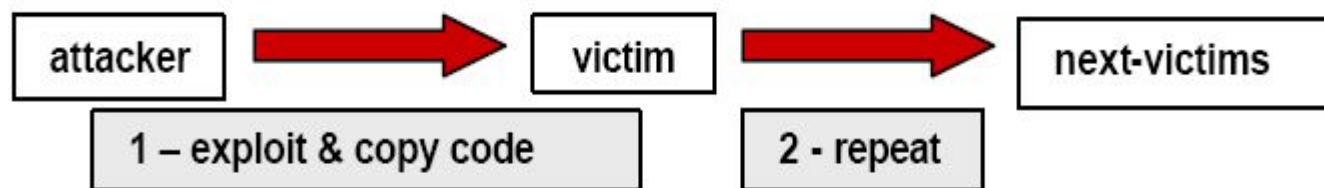


Malware propagation methods cont'd....

- Back chaining/pull approach



- Autonomous/push approach



Source: www.cert.org/archive/pdf/DoS_trends.pdf



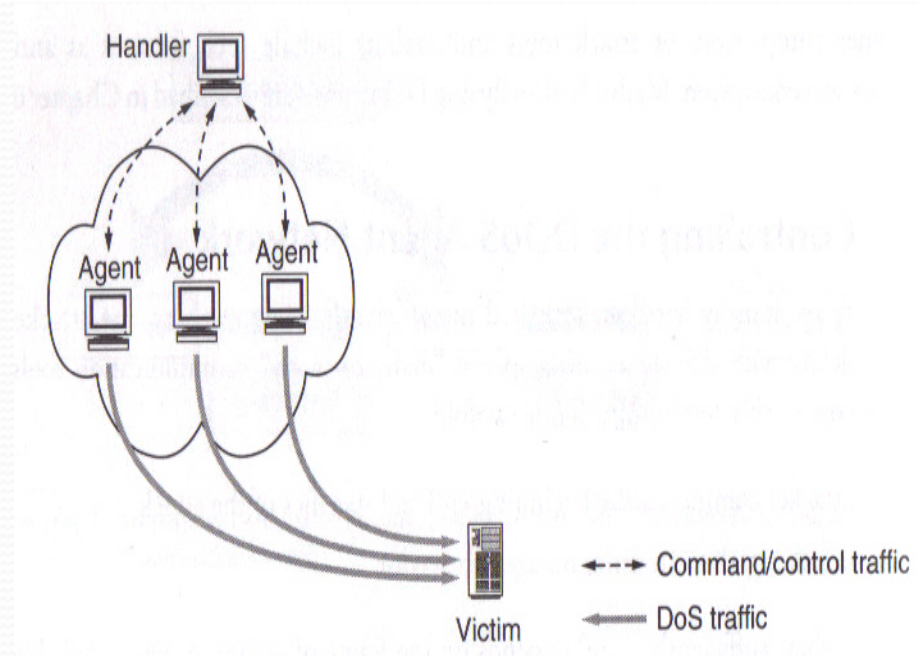
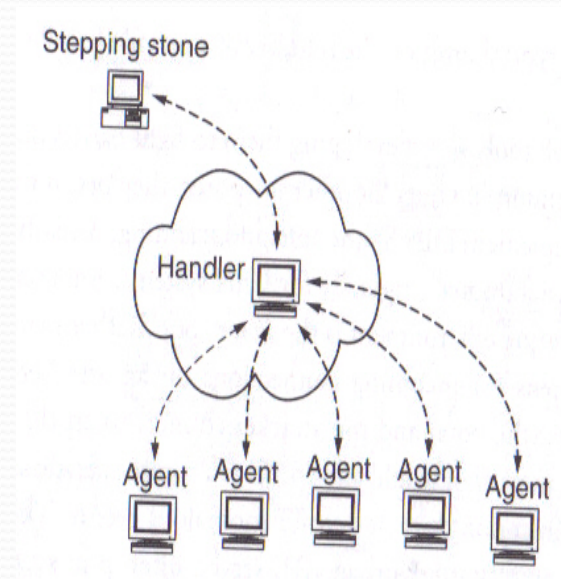
Controlling DDoS agent network

- Attacker communicates with agents using “**many-to-many**” communication tools
- Twofold-purpose for attacker
 - To command the beginning/ending and specifics of attack
 - To gather statistics on agent behaviour
- Strategies for establishing control
 - Direct command control
 - Indirect command control

Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



Direct commands control



Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



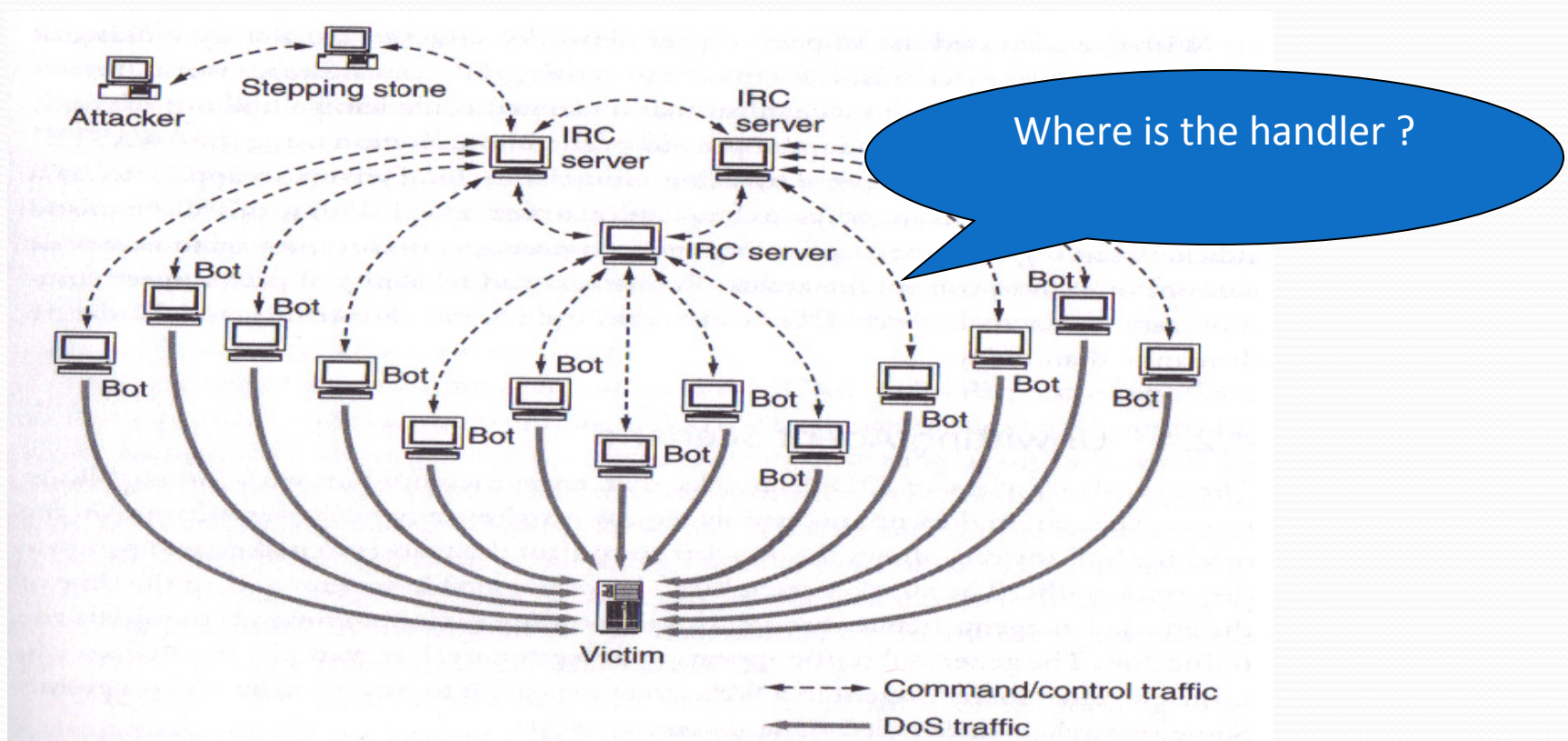
Drawbacks of direct command control

- If one machine is captured, the whole DDoS network could be identified
- Any anomalous event on network monitor could be easily spotted
- Both handlers and agents need to be **ready always** to receive messages
 - Opening ports and listening to them
 - Easily caught

Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



Indirect command control



Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



Advantages of IRC to attacker

- Server is maintained by others
- The **channel(handler)** **not easily recognisable** amidst thousands of other channels
- Even though channel is discovered, it can be removed only through cooperation of the server's administrators
- By turning compromised hosts to rogue IRC servers, attackers are a step ahead in concealing their identity

Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



DDoS attack toolkits

- Some popular DDoS programs
 - Trinoo,TFN,Stacheldraht,Shaft,TFN2K,Mstream,Trinity,Phatbot
- Blended threat toolkits: Include some (all) of the following components
 - Windows network service program
 - Scanners
 - Single-threaded DoS programs
 - An FTP server
 - An IRC file service
 - An IRC DDoS Bot
 - Local exploit programs
 - Remote exploit programs
 - System log cleaners

Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



DDoS attack toolkits cont'd

- Trojan Horse Operating systems program replacements
- Sniffers
- **Phatbot** implements a large percentage of these functions in a single program

Source: Mirkovic, J., Dietrich, S., Dittrich, D., & Reiher, P. (2005)



Contents

- Introduction
- Classical DoS attacks
- Flooding attacks
- Distributed Denial-of-Service (DDoS)
- How DDoS attacks are waged?
- Reflector and amplifier attacks
- Other DoS attacks
- Detecting DoS attacks
- Approaches to defense against DoS
- Responding to a DoS attack
- Conclusion



Reflector and amplifier attacks

- Unlike DDoS attacks, the intermediaries are *not compromised*
- R & A attacks use *network systems functioning normally*
- Generic process:
 - A network packet with a spoofed source address is sent to a service running on some network server
 - A response to this packet is sent to the spoofed address(victim) by server
 - A number of such requests spoofed with same address are sent to various servers
 - A large flood of responses overwhelm the target's network link
- Spoofing utilised for reflecting traffic
- These attacks are **easier to deploy and harder to trace back**



Reflection attacks

- Direct implementation of the generic process explained before
 - **Reflector** : Intermediary where the attack is reflected
 - Make sure the packet flow is similar to legitimate flow
- Attacker's preference: ***response packet size > original request size***
- Various protocols satisfying this condition are preferred
 - UDP, chargen, DNS, etc
- Intermediary systems are often high-capacity network servers/routers
- **Lack of backscatter traffic**
 - No visible side-effect
 - Hard to quantify



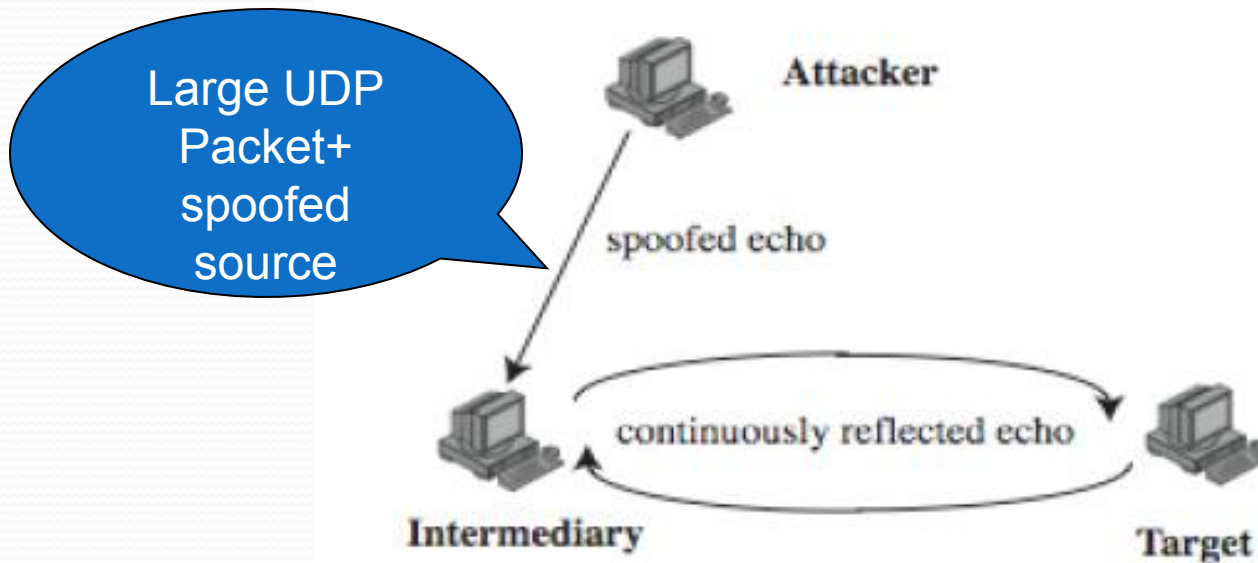
Reflection attack using TCP/SYN

- **Exploits three-way handshake** used to establish TCP connection
 - A number of SYN packets spoofed with target's address are sent to the intermediary
- Flooding attack but different from SYN spoofing attack
- **Continued correct functioning** is essential
- Many possible intermediaries can be used
 - Even if some intermediaries sense and block the attack, many other won't



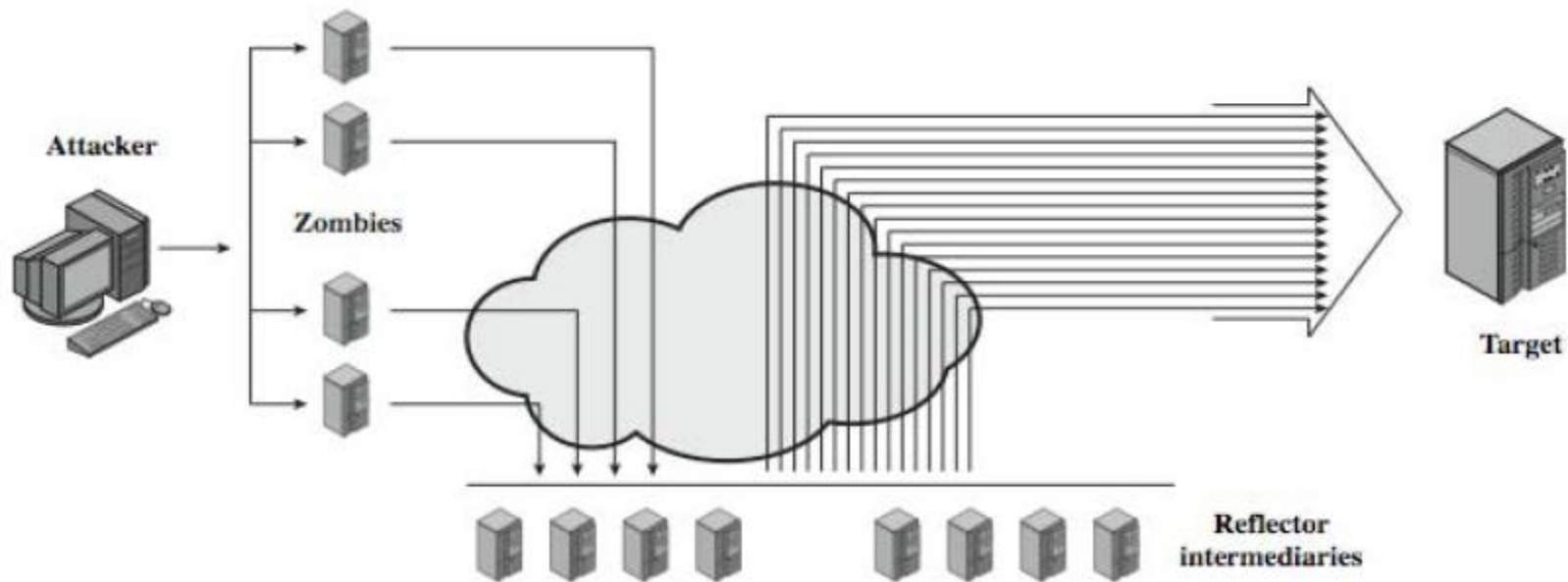
Further variation

- Establish self-contained loop(s) between the intermediary and the target system using diagnostic network services (echo,chargen)
- Fairly easy to filter and block



Amplification attacks

- Differ in intermediaries generate **multiple response packets** for each original packet sent



Amplification attacks possibilities

- Utilize service handled by large number of hosts on intermediate network
- A ping flood using ICMP echo request packets
 - Ex: smurf DoS program
- Using suitable UDP service
 - Ex: fraggle program
- TCP service cannot be used



Defense from amplification attack

- Not to allow directed broadcasts to be routed into a network from outside



Smurf DoS program

- Two main components
 - Send **source-forged ICMP echo packet** requests from **remote locations**
 - Packets directed to **IP broadcast addresses**
- If the intermediary does not filter this broadcast traffic, many of the machines on the network would receive and respond to these spoofed packets
 - When entire network responds, successful smurf DoS has been performed on the target network
- Besides victim network, intermediary network might also suffer
 - Smurf DoS attack with single/multiple intermediary(s)
 - Analyze network routers that do not filter broadcast traffic
 - Look for networks where multiple hosts respond

Source: <http://www.cert.org/advisories/CA-1998-01.html>



DNS amplification attacks

- DNS servers is the intermediary system
- Exploit DNS behavior to convert a small request to a much larger response
 - 60 byte request to 512 – 4000 byte response
- Sending DNS requests with spoofed source address being the target to the chosen servers
- Attacker sends requests to multiple well connected servers, which flood target
 - Moderate flow of packets from attacker is sufficient
 - Target overwhelmed with amplified responses from server



Contents

- Introduction
- Classical DoS attacks
- Flooding attacks
- Distributed Denial-of-Service (DDoS)
- How DDoS attacks are waged?
- Reflector and amplifier attacks
- Other DoS attacks
- Detecting DoS attacks
- Approaches to defense against DoS
- Responding to a DoS attack
- Conclusion



Teardrop

- This DoS attack affects Windows 3.1, 95 and NT machines and Linux versions previous to 2.0.32 and 2.1.63
- **Teardrop** is a program that sends IP fragments to a machine connected to the Internet or a network
- **Teardrop** exploits an overlapping IP fragment bug
 - The bug causes the TCP/IP fragmentation re-assembly code to improperly handle overlapping IP fragments
 - A 4000 bytes of data is sent as
 - Legitimately (Bytes 1-1500) (Bytes 1501 – 3000) (Bytes 3001-4500)
 - Overlapping (Bytes 1-1500) (Bytes 1501 – 3000) (Bytes 1001-3600)
- This attack has not been shown to cause any significant damage to systems
- The primary problem with this is loss of data

Source: Fadia (2007)



Cyberslam

- DDoS attack in a different style
- Zombies DO NOT launch a SYN Flood or issue dummy packets that will congest the Web server's access link
- Zombies fetch files or **query search engine databases at the Web server**
- From the web server's perspective, these zombie requests look exactly like legitimate requests
- so the server ends up spending lot of its time serving zombies, causing DoS to legitimate users

Source: Kandula (2005)



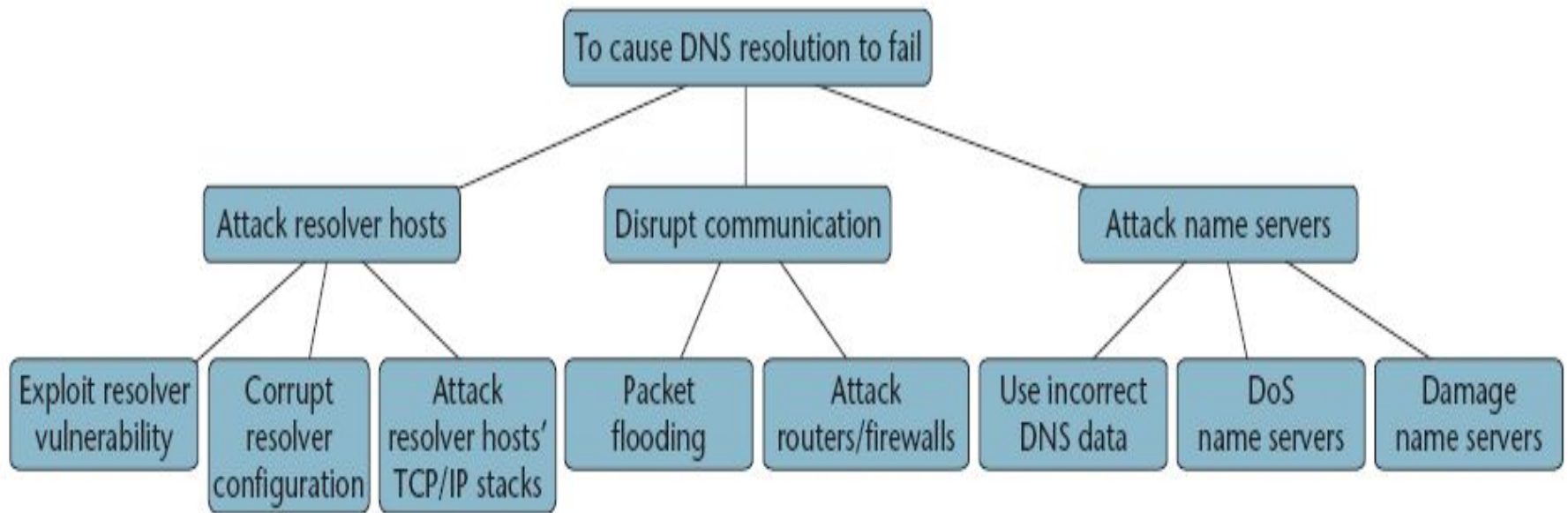
Techniques to counter cyberslam

- Password authentication
 - Cumbersome to manage for a site like Google
 - Attacker might simply DDoS the password checking mechanism
- Computational puzzles
 - Computation burden quite heavy compared to service provided
- Graphical puzzles
- Kill-bots suggested in [Kandula 2005]

Source: Kandula (2005)



Attack tree: DoS against DNS



Source: Cheung (2006)



How to protect DNS from (D)DoS ?

- Multiple scattered name servers
- Anycast routing
 - Multiple name servers sharing common IP address
- Over-provisioning of host resources and network capacity
- Diversity
 - DNS software implementation, OS, hardware platforms
- TSIG : The transaction signature
- Use of dedicated machines

Source: Cheung (2006)



Contents

- Introduction
- Classical DoS attacks
- Flooding attacks
- Distributed Denial-of-Service (DDoS)
- How DDoS attacks are waged?
- Reflector and amplifier attacks
- Other DoS attacks
- Detecting DoS attacks
- Approaches to defense against DoS
- Responding to a DoS attack
- Conclusion



DoS detection techniques

- Detector's goal: To **detect** and **distinguish** malicious packet traffic from legitimate packet traffic
- **Flash crowds**: High traffic volumes may also be accidental and legitimate
 - **Highly publicised websites**: (unpredictable) Slashdot news aggregation site
 - **Much-awaited events**: (Predictable) Olympics, Soccer etc.
- There is no innate Internet mechanism for performing malicious traffic discrimination
- Once detected, vulnerability attacks are easy to be addressed
- If vulnerability attacks volume is so high that it manifests as flooding attack, very difficult to handle

Source: Carl (2006)



Vulnerability attack detection techniques

- Detection techniques can be installed locally or remotely
 - Locally : detectors placed at potential victim resource or at a router or firewall within the victim's subnetwork
 - Remotely: To detect propagating attacks
- Attack defined by detection methods: an abnormal and noticeable deviation of **some statistic** of the monitored network traffic workload
 - Proper choice of statistic is crucial

Source: Cheung (2006)



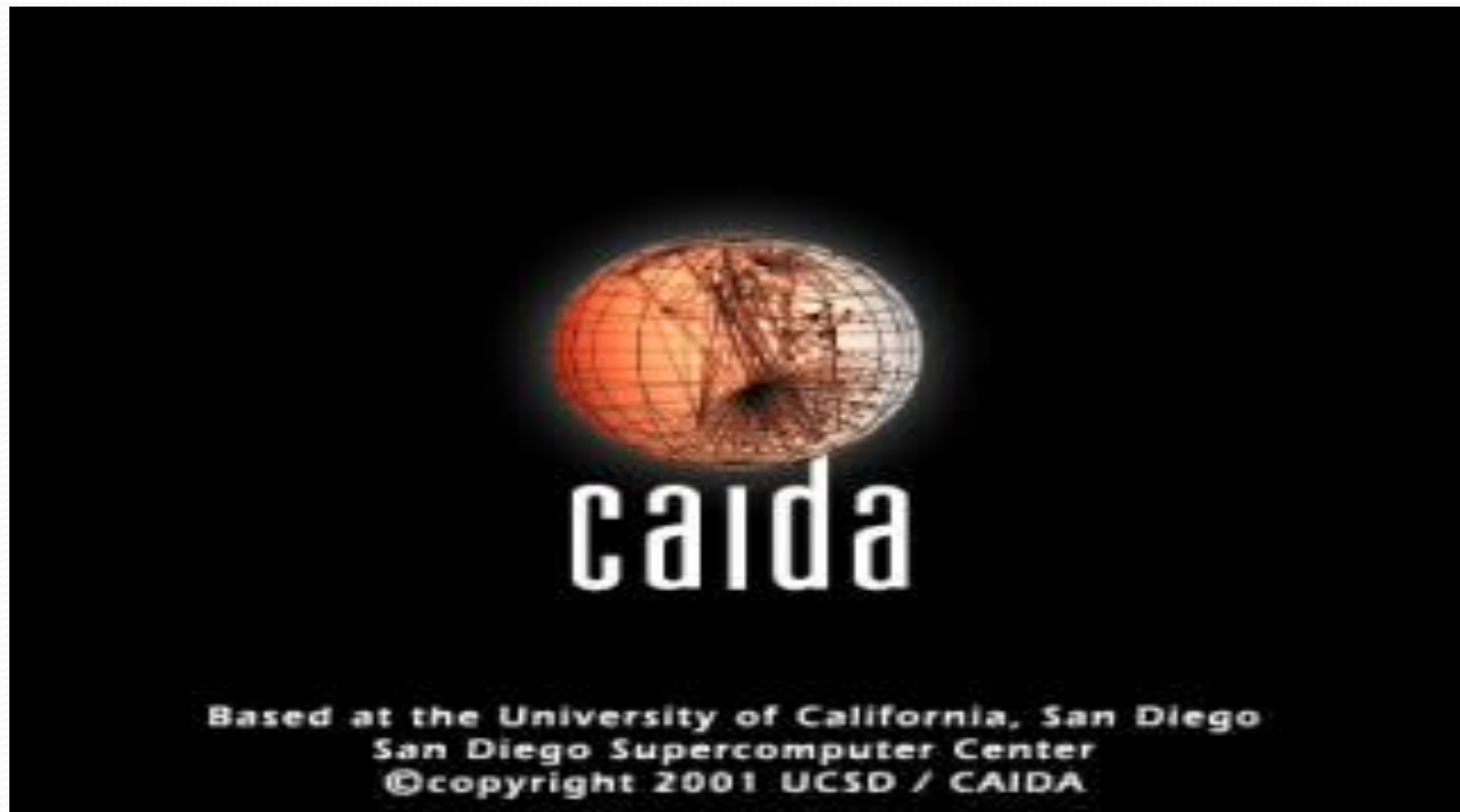
Statistical detection methods

- Activity profiling: Monitoring network packet's header information
 - Backscatter analysis
- Sequential change-point detection
 - Chi-Square/Entropy Detector
- Wavelet Analysis
 - Cusum and wavelet approaches

Source: Cheung (2006)

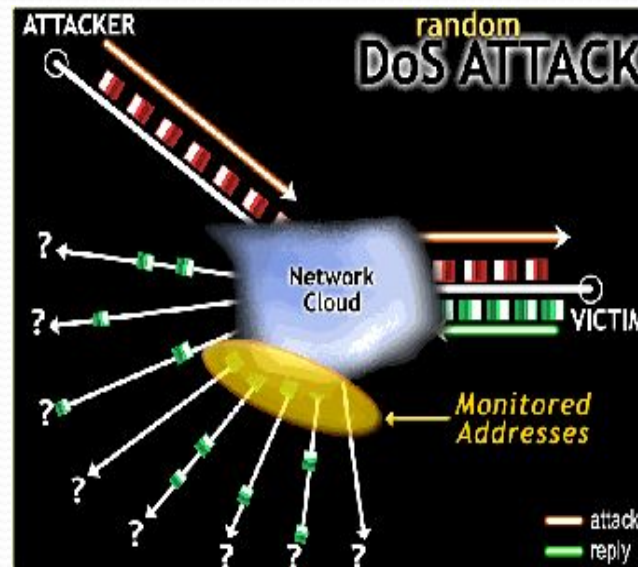


Backscatter



Backscatter cont'd

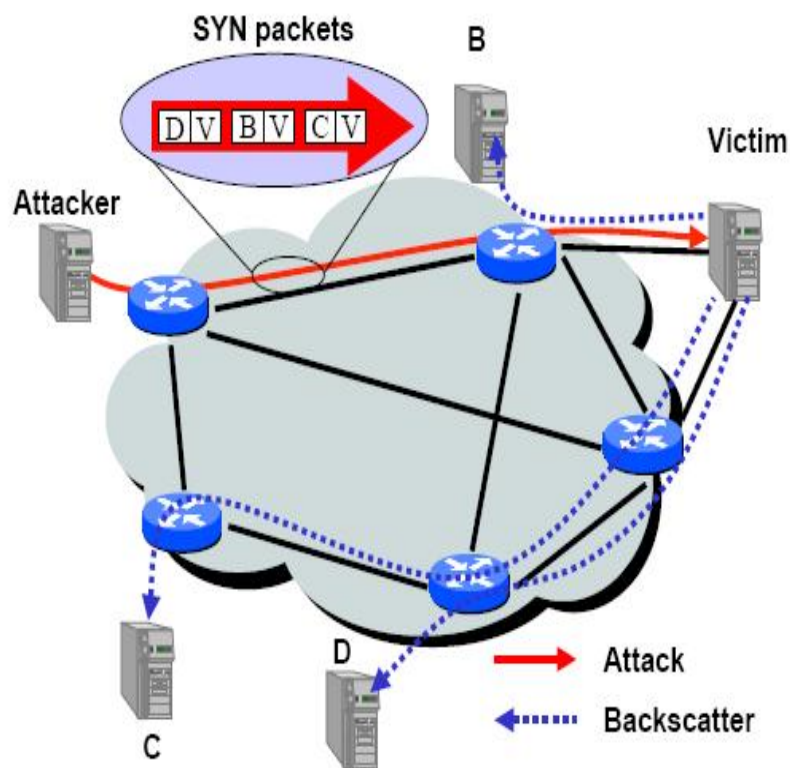
- Generally, source addresses chosen at *random* for spoofing based flooding attacks
- Unsolicited Victim's responses are *equi-probably distributed* (**Backscattered**) across the entire Internet address space
 - Received backscatter **evidence of presence of attacker**



Source: Moor (2006)



Backscatter analysis



- Backscatter analysis used to **quantify** the **prevalence** of DoS attacks and identify the type of attack
- Assumptions :
 - Address uniformity
 - Reliable delivery
 - One response generated for every packet in an attack
- Backscatter hypothesis
 - Unsolicited packets observed by the monitor represent backscatter

Source: Moor (2006)

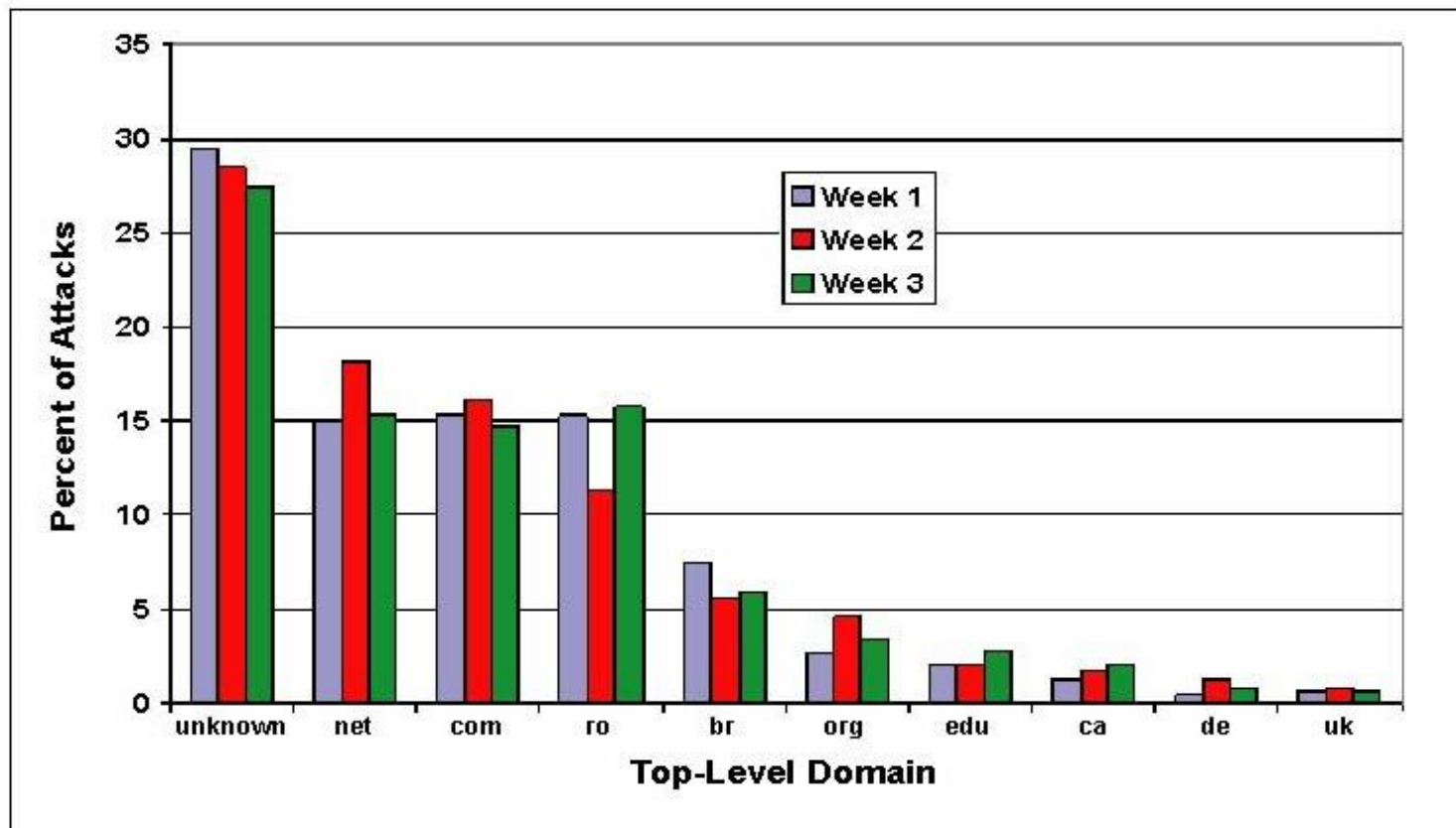


Quantification using backscatter

Network Telescope : Monitoring block of n IP addresses	
Probability of a given host receiving at least one unsolicited response from victim during an attack of m packets	$1 - \left(1 - \frac{1}{2^{32}}\right)^m$
Probability of n hosts receiving at least one unsolicited response from victim during an attack of m packets	$1 - \left(1 - \frac{n}{2^{32}}\right)^m$
Expected # of backscatter packets given an attack of m packets at a single host	$\frac{m}{2^{32}}$
Expected # of backscatter packets given an attack of m packets at n hosts	$E(X) = \frac{nm}{2^{32}}$
Average arrival rate of unsolicited responses (R' is the measured avg. inter-arrival backscatter rate R is the extrapolated attack rate in pps)	$R \geq R' \frac{2^{32}}{n}$



What types of machines are attacked?



Top-Level Domain.

The percentage of all attacks incurred by each Top-Level Domains.

Moor (2006)



Contents

- Introduction
- Classical DoS attacks
- Flooding attacks
- Distributed Denial-of-Service (DDoS)
- How DDoS attacks are waged?
- Reflector and amplifier attacks
- Other DoS attacks
- Detecting DoS attacks
- Approaches to defense against DoS
- Responding to a DoS attack
- Conclusion



Defenses against DoS attacks

- DoS attacks cannot be prevented entirely
- Impractical to prevent the **flash crowds** without compromising network performance
- Three lines of defense against (D)DoS attacks
 - Attack prevention and preemption
 - Attack detection and filtering
 - Attack source traceback and identification



Attack prevention

- Limit ability of systems to send spoofed packets
 - Filtering done as close to source as possible by routers/gateways
 - Reverse-path filtering ensure that the path back to claimed source is same as the current packet's path
 - Ex: On Cisco router “ip verify unicast reverse-path” command
- Rate controls in upstream distribution nets
 - On specific packet types
 - Ex: Some ICMP, some UDP, TCP/SYN
- Use modified TCP connection handling
 - Use SYN-ACK cookies when table full
 - Or selective or random drop when table full



Attack prevention cont'd

- Block IP broadcasts
- Block suspicious services & combinations
- Manage application attacks with “puzzles” to distinguish legitimate human requests
- Good general system security practices
- Use mirrored and replicated servers when high performance and reliability required



October 2009

- 6th Annual National Cybersecurity Awareness Month
- One of the themes: shared responsibility

**Shut down your pcs
whenever
possible!!!!**



Contents

- Introduction
- Classical DoS attacks
- Flooding attacks
- Distributed Denial-of-Service (DDoS)
- How DDoS attacks are waged?
- Reflector and amplifier attacks
- Other DoS attacks
- Detecting DoS attacks
- Approaches to defense against DoS
- Responding to a DoS attack
- Conclusion



Responding to attacks

- Need good incident response plan
 - With contacts for ISP
 - Needed to impose traffic filtering upstream
 - Details of response process
- Have standard antispooofing, rate limiting, directed broadcast limiting filters
- Ideally have network monitors and IDS
 - To detect and notify abnormal traffic patterns



Responding to attacks cont'd

- Identify the type of attack
 - Capture and analyze packets
 - Design filters to block attack traffic upstream
 - Identify and correct system application bugs
- Have ISP trace packet flow back to source
 - May be difficult and time consuming
 - Necessary if legal action desired
- Implement contingency plan
- Update incident response plan



Contents

- Introduction
- Classical DoS attacks
- Flooding attacks
- Distributed Denial-of-Service (DDoS)
- How DDoS attacks are waged?
- Reflector and amplifier attacks
- Other DoS attacks
- Detecting DoS attacks
- Approaches to defense against DoS
- Responding to a DoS attack
- Conclusion



Conclusion

- (D)DoS attacks are *genuine threats* to many Internet users
- Annoying < I < Debilitating ; I = losses
- Level of loss is related to motivation as well shielding attempts from the defender
 - Attackers taking advantage of ignorance of the victims w.r.t. (D)DoS attacks
- Defensive measures might not always work
 - Neither threat nor defensive methods are static
- Prognosis for DDoS
 - Increase in size
 - Increase in sophistication
 - Increase in semantic DDoS attacks
 - Infrastructure attacks
- DDoS are significant threats to the future growth and stability of Internet



Thank you!

Questions ?

